

Lab 3: Logs de Linux: syslog, journald i eines locals

Detecció d'amenaçes

GEI | FIB | Curs 2026/2027



UNIVERSITAT POLITÈCNICA DE CATALUNYA
BARCELONATECH

Facultat d'Informàtica de Barcelona



UNIVERSITAT POLITÈCNICA DE CATALUNYA
BARCELONATECH

Facultat d'Informàtica de Barcelona

Detecció d'amengaces

Assignatura amb 22 hores de laboratori corresponent a l'especialitat:

Tecnologies de la informació

Inclousa en el:

Grau en Enginyeria Informàtica



Sobre mi

- **MANEL RODERO**

- Administrador de Sistemes, [Universitat Politècnica de Catalunya](#):
 - [UTGCNTIC](#) [2019 – actualitat]
 - [inLab FIB](#) [2012 – 2019]
 - LCFIB [1996 – 2012]
- Analista de Seguretat, [esCERT-UPC](#) [2013 – 2017]
- Enginyer Informàtic, [Facultat d'Informàtica de Barcelona](#) [1999]
- Contacte:
 - manel.rodero@upc.edu

Lab 3. Logs de Linux: syslog, journald i eines locals

Administrar, analitzar i monitoritzar logs dels SO Linux



El repte de detectar amenaces a Linux

- On es registren els intents de login o els errors dels serveis?
- Com analitzem centenars d'esdeveniments per segon?
- Linux utilitza **dos sistemes de logging que conviuen**:
 - `/var/log` → fitxers de text en format syslog
 - `journald` → format binari propi i noves eines (`journalctl`)
- Les distribucions modernes (com Debian, Ubuntu, etc.) utilitzen **rsyslog** i **journald** alhora:
 - `journald` rep els esdeveniments
 - `rsyslog` pot exportar-los a `/var/log`

"Avui aprendrem a llegir i interpretar evidències en tots dos sistemes"

El directori `/var/log`

- Aquest directori conté fitxers de text en format syslog
- Alguns dels fitxers més importants i el seu contingut són:

Fitxer	Descripció
<code>syslog</code>	Missatges globals del sistema
<code>dmesg</code>	Informació del kernel, incloent els dispositius hardware que es detecten quan el sistema inicia (es llegeix amb <code>dmesg</code>)
<code>auth.log</code>	Informació d'autorització, incloent els inicis de sessió d'usuari i el mecanisme d'autenticació que s'utilitza
<code>cron.log</code>	Execucions del planificador de tasques
<code>daemon.log</code>	Informació registrada pels dimonis en segon pla que s'executen en el sistema
<code>dpkg.log</code>	Instal·lació i eliminació de paquets
<code>btmpt</code>	Intents d'accés fallits (es llegeix amb <code>lastb</code> ; no és text pla)

Syslog

- El **protocol**, definit al [RFC5424](#)
 - UDP/514
 - Sense estat entre client i servidor
 - Sense autenticació del remitent ni del receptor dels missatges
 - Sense justificació de recepció
 - Contingut del missatge o format no estandaritzat
- Els **missatges** de registre reals (per la xarxa o en fitxers)
- Les **eines** utilitzades per recol·lectar, processar i guardar missatges de registre ([rsyslog](#), [syslog-ng](#), etc.)

Syslog: Missatges

- Els missatges de syslog inclouen informació bàsica que identifica on, quan i perquè es va enviar un log
 - Adreça IP, marca de temps, missatge de log
- Syslog utilitza el concepte "**facility**" per identificar l'origen d'un missatge d'una màquina concreta
 - Per exemple, la facilitat "0" és utilitzada pels missatges del kernel
- Els missatges de syslog també inclouen un camp per indicar el nivell de gravetat ("**severity**")
 - Per exemple, la severitat "0" indica emergència
- La combinació de la severitat i la facilitat s'anomena prioritat ("**priority**")

Syslog: Facilitats

Facilitat	Descripció
auth (4)	Missatges de seguretat i autoritzacions relacionats amb la sol·licitud de nom i contrasenya: <code>getty</code> , <code>su</code> , <code>login</code>
authpriv (10)	Ídem però registrats en un fitxer que únicament poden llegir usuaris autoritzats
cron (9)	Missatges de dimonis periòdics: <code>cron</code> , <code>at</code> , ...
daemon (3)	Altres dimonis del sistema; és de tipus catch-all
kern (0)	Missatges del nucli
local0 ... local7 (16 ... 23)	Reservades per a ús local
mark	Per generar marques de temps en els fitxers de log
syslog (5)	Missatges interns de syslog
ftp (11), lpr (6), mail (2), news (7), ntp (12), uucp (8)	Altres subsistemes
user (1)	Missatges d'aplicacions d'usuari

Syslog: Severitats



Severitat	Descripció
emerg (0)	Condició d'emergència, sistema inestable o possible crash imminent; habitualment difós a tots els usuaris
alert (1)	Condició que requereix acció immediata, per exemple, una base dades de sistema corrupta
crit (2)	Error crític, como per exemple, una errada hardware
err (3)	Condició d'error ordinària, como errades en una aplicació
warning (4)	Condició d'avís
notice (5)	Missatge significatiu; no és un error però s'hauria de tractar d'alguna manera
info (6)	Missatge informatiu
debug (7)	Sortida de depuració
none	Nivell especial utilitzat per no registrar missatges

Fitxer /etc/syslog.conf

- Cada línia del fitxer consta de dues parts:
 - **Selector:** especifica quin tipus de missatge cal registrar
 - **Acció:** indica què cal fer amb el missatge

```
auth,authpriv.*      /var/log/auth.log
*.*;auth,authpriv.none -/var/log/syslog
cron.*                /var/log/cron.log
```

- Un selector té dues parts: una facilitat i una severitat
- Les severitats són inclusives (més gran o iguals que la indicada)
 - `kern.debug` = tots els missatges generats pel kernel amb severitat `debug` o més greu

Syslog: Accions

Destí	Descripció
Fitxer	- És necessari indicar la ruta completa al fitxer ("/") - El fitxer ha d'existir y <code>syslogd</code> ha de poder escriure en ell - El símbol menys ("-") omet la sincronització a disc <code>/var/log/lpr.log</code>
Programa (" ")	- És necessari crear una <i>named pipe</i> amb la comanda <code>mkfifo</code> - Es necessita un script que la llegeixi i processi constantment <code> /var/adm/syslog.pipe</code>
Terminal i consola	<code>/dev/tty8</code> <code>/dev/console</code>
Host remot ("@")	<code>@syslog_remoto</code>
Usuaris	<code>root, webmaster</code>
Tots els usuaris	<code>*</code>

Què és journald?

- Subsistema de systemd que gestiona el logging modern de Linux
- Emmagatzema els esdeveniments en un **format binari indexat**
 - Permet consultes molt més ràpides que els fitxers de text
- Cada entrada inclou **metadades estructurades**
 - PID, UID, unitat systemd, prioritat, execució, etc.
- Centralitza logs de **kernel, serveis systemd, processos i dispositius**
- Ofereix filtratge avançat amb `journalctl`
 - Per unitat, per temps, per prioritat, etc.

Eina `journalctl`

- Comandes bàsiques:

- `journalctl`: mostra tots els logs
- `journalctl -u ssh`: logs d'una unitat concreta
- `journalctl -b`: només des del darrer inici del sistema
- `journalctl -p err`: només errors
- `journalctl -f`: seguiment en temps real (tail)

- Opcions útils:

- `-r`: ordre invers (més recents primer)
- `--since "2024-03-12 10:00"`: filtratge temporal
- `--since "1 hour ago"`: filtratge temporal
- `-o json`: format estructurat

Sysmon for Linux

- No hi ha Event ID numèrics com a Windows
- Registra esdeveniments en JSON i els envia a syslog/journald
- Basat en eBPF: captura execució, xarxa, etc. amb baix overhead
- Configuració amb XML, amb camps i opcions específiques
- Telemetria centrada en:
 - execve (creació de processos)
 - Connexions TCP/UDP
 - Càrrega de biblioteques (ld.so)
 - Canvis de fitxers (creació, eliminació)
 - Pipes i sockets

Exemple de fitxer de configuració XML

```
<Sysmon schemaversion="4.50">
  <EventFiltering>

    <!-- Registre de creació de processos (execve) -->
    <ProcessCreate onmatch="include">
      <Image condition="contains">/usr/bin</Image>
      <Image condition="contains">/bin</Image>
    </ProcessCreate>

    <!-- Connexions de xarxa (TCP/UDP) -->
    <NetworkConnect onmatch="include">
      <DestinationPort condition="is">22</DestinationPort>
      <DestinationPort condition="is">443</DestinationPort>
    </NetworkConnect>

  </EventFiltering>
</Sysmon>
```

Preparació de l'entorn virtual



- Anar a <http://virtech.fib.upc.edu/>
- Crear 1 VM (com a mínim):
 - Assignar contrasenya "alumne"
 - No oblidar-la (no recuperable)
 - Accedir a la màquina VM
 - Localitzar la IP assignada
 - Connectar amb SSH (alumne@ip)
 - Actualitzar els paquets d'Ubuntu
 - `sudo apt update`
 - `sudo apt upgrade -y`
 - Reiniciar per aplicar els canvis

Exercicis dirigits

- Demo A: Generar un missatge de text
 - `logger -p <pri> -t <tag> "Missatge des de $(whoami) "`
 - Comprovar que apareix a `syslog` y `journald`
- Demo B: Simular una seqüència d'intents de login fallits
 - Executar l'script `Lab3-generar-registres.sh`
 - Aquest script **injecta** al log local una seqüència realista d'**intents d'autenticació** (fallits i correcte)
- Demo C: Analitzar-ho amb `grep` i amb `journalctl`, comparant els dos mètodes
- Demo D: Omplir la fitxa de resultat #1

Lab3-generar-registres.sh

```
#!/bin/bash
IPS=(203.0.113.5 198.51.100.23 203.0.113.5 192.0.2.44 \
    203.0.113.5 198.51.100.23 203.0.113.5 192.0.2.44 \
    203.0.113.5 203.0.113.5)
for ip in "${IPS[@]}; do
    logger -p auth.warning -t sshd \
        "Failed password for admin from $ip port 22 ssh2"
    sleep 1
done
logger -p auth.notice -t sshd \
    "Accepted password for admin from 203.0.113.5 port 22 ssh2"
```

Fitxa de resultat #1

- Mètode(s) utilitzat(s): `grep sobre /var/log/auth.log i journalctl -t sshd`
- Nombre total d'intents fallits: 10
- Compte(s) objectiu i recompte: admin (10)
- IP origen i recompte: 203.0.113.5 (6), 198.51.100.23 (2) i 192.0.2.44 (2)
- Classificació MITRE ATT&CK: [T1110.001](#) (password guessing)
- Coincideixen els resultats de grep i journalctl?: Sí
- Conclusió breu: L'atac s'origina majoritàriament des d'una única IP i acaba amb èxit contra el mateix compte objectiu des d'aquesta IP. És un patró clàssic de força bruta dirigida.

Treball autònom en parelles



- El treball s'ha d'entregar en **1 únic fitxer PDF per grup** amb:
 - Fitxes completades
 - Comandes executades i resultat
- El nom del fitxer ha de tenir aquest format:
 - `Lab3_grupXX_cognom1_cognom2.pdf`
- L'entrega es fa mitjançant el **Racó**
- Teniu fins a la **mitjanit** del següent dimarts o divendres per entregar

Analitzar l'escenari 1 (1 punt)

- Executar script `Lab3-escenari1.sh`
- Analitzar els logs generats fent servir **tots dos mètodes** (grep i journalctl)
- Obtenir timestamp, mètode (password/publickey) i IP d'origen
- Identificar quina IP és la "habitual" i quines són les anòmales
- Calcular l'interval de temps entre accessos (IP habitual → IP anòmala)
- Raonar si aquest interval és compatible amb un desplaçament físic real d'una persona entre les ubicacions associades a aquestes IPs
- Classificar l'escenari segons les tècniques de MITRE ATT&CK
- Completar la **fitxa de resultat de l'escenari 1 més endavant**

Lab3-escenari1.sh

```
#!/bin/bash
logger -p auth.notice -t sshd \
    "Accepted password for svc-backup from 203.0.113.50 port 22 ssh2"
sleep 2
logger -p auth.notice -t sshd \
    "Accepted password for svc-backup from 203.0.113.50 port 22 ssh2"
sleep 15
logger -p auth.notice -t sshd \
    "Accepted publickey for svc-backup from 198.51.100.90 port 22 ssh2: RSA SHA256:AbCdEf1234567890"
sleep 20
logger -p auth.notice -t sshd \
    "Accepted password for svc-backup from 192.0.2.15 port 22 ssh2"
sleep 10
logger -p auth.notice -t sshd \
    "Accepted password for svc-backup from 203.0.113.50 port 22 ssh2"
```

Fitxa de resultat Escenari 1

- Mètode(s) utilitzat(s) per analitzar:
- Compte implicat:
- IP "habitual" i nombre de connexions:
- IP(s) anòmala(s) i timestamp de cadascuna:
- Interval entre l'última connexió habitual i la primera anòmala:
- Interval entre les dues connexions anòmales:
- Hi ha cap intent fallit (Si/No)?:
- És possible un desplaçament físic real (Si/No)? Per què?
- Classificació de l'atac segons MITRE ATT&CK:
- Conclusió breu (2 o 3 línies màxim):

Analitzar l'escenari 2 (1 punt)

- Executar script `Lab3-escenari2.sh`
- Analitzar els logs generats fent servir **tots dos mètodes** (grep i journalctl)
- Comprovar que els resultats coincideixen
- Identificar el compte objectiu i la IP origen
- Comparar les raons de sospita d'aquest escenari (IP/timestamp) amb les de l'escenari anterior (errors)
- Classificar l'escenari segons les tècniques de MITRE ATT&CK
- Completar la **fitxa de resultat de l'escenari 2 més endavant**

Lab3-escenari2.sh

```
#!/bin/bash
USERS=(admin backup mysql www-data ftpuser \
        guest oracle postgres jenkins)
for u in "${USERS[@]}"; do
    logger -p auth.warning -t sshd \
        "Failed password for $u from 198.51.100.77 port 22 ssh2"
done
logger -p auth.notice -t sshd \
    "Accepted password for deploy from 198.51.100.77 port 22
ssh2"
```

Fitxa de resultat Escenari 2

- Mètode(s) utilitzat(s) per analitzar:
- Nombre total d'intents fallits:
- Compte(s) objectiu i recompte:
- IP(s) origen i recompte:
- Esdeveniment d'èxit (Si/No), compte i IP associats:
- Classificació de l'atac segons MITRE ATT&CK:
- Coincideixen els resultats de grep i journalctl?:
- Conclusió breu (2 o 3 línies màxim):

Analitzar l'escenari 3 (1 punt)

- Executar script `Lab3-escenari3.sh`
- Analitzar els logs generats fent servir **tots dos mètodes** (grep i journalctl)
- Comprovar que els resultats coincideixen
- Identificar l'usuari que intenta escalar
- Identificar la comanda executada un cop escalat
- Classificar l'escenari segons les tècniques de MITRE ATT&CK
- Completar la **fitxa de resultat de l'escenari 3 més endavant**

Lab3-escenari3.sh

```
#!/bin/bash
for i in 1 2 3; do
    logger -p auth.warning -t sudo \
        "pam_unix(sudo:auth): authentication failure; logname=
uid=1000 euid=0 tty=/dev/pts/0 ruser=labuser rhost= user=root"
    sleep 1
done
logger -p auth.notice -t sudo \
    "labuser : TTY=pts/0 ; PWD=/home/labuser ; USER=root ;
COMMAND=/bin/bash"
```

Fitxa de resultat Escenari 3

- Mètode(s) utilitzat(s) per analitzar:
- Nombre total d'intents fallits:
- Usuari que intenta escalar:
- Comanda executada un cop escalat:
- Classificació de l'atac segons MITRE ATT&CK:
- Coincideixen els resultats de grep i journalctl?:
- Conclusió breu (2 o 3 línies màxim):

Configurar rutes pròpies a rsyslog (1 punt)

- Encaminar els missatges de la facilitat **local0** cap a un fitxer propi:
 - Destí: `/var/log/lab3-da.log`
- Casos a configurar:
 - Cas 1) Enviar-hi **tots** els missatges de **local0** (qualsevol severitat)
 - Cas 2) Enviar-hi **només** els de local0 amb severitat **warning** o superior
 - Cas 3) Modificar la regla `*.*` perquè exclogui local0 i el missatge només aparegui al fitxer propi (sense duplicar-se a `/var/log/syslog`)
- Generar missatges amb logger i comprovar a quins fitxers apareixen
- Per cada cas cal entregar:
 - la **línia** (o **línies**) de rsyslog que s'han afegit o modificat
 - la comanda logger utilitzada per provar la configuració
 - la comanda i la sortida demostrant que el missatge apareix (o no) on toca

Instal·lació i ús de Sysmon for Linux

- Seguir la documentació per instal·lar a Ubuntu
 - `lsb_release -rs`
 - Descarregar i instal·lar el fitxer *.deb amb els repos de Microsoft
 - Actualitzar repos locals i instal·lar el paquet `sysmonforlinux`
- Configurar-lo, iniciar-lo i generar activitat "maliciosa"
 - Feu servir el fitxer d'exemple XML mostrat a classe
 - Generar activitat "maliciosa" segons el fitxer XML utilitzat anteriorment

```
whoami  
curl -s -o /dev/null https://www.upc.edu/
```

- Veure els esdeveniments **detectats**

```
sudo journalctl -u sysmon --no-pager | tail -40  
sudo journalctl -u sysmon --no-pager | /opt/sysmon/sysmonLogView
```